



JOINT CANADA-UNITED STATES
NATIONAL STANDARD

ANSI/CAN/UL 2900- 2-1:2023A

STANDARD FOR SAFETY

Software Cybersecurity for Network-
Connectable Products, Part 2-1:
Particular Requirements for Network
Connectable Components of
Healthcare and Wellness Systems



UL 2900-2-1-2023



SCC FOREWORD

National Standard of Canada

A National Standard of Canada is a standard developed by a Standards Council of Canada (SCC) accredited Standards Development Organization, in compliance with requirements and guidance set out by SCC. More information on National Standards of Canada can be found www.scc.ca.

SCC is a Crown corporation within the portfolio of Innovation, Science and Economic Development (ISED) Canada. With the goal of enhancing Canada's economic competitiveness and social well-being, SCC leads and facilitates the development and use of national and international standards. SCC also coordinates Canadian participation in standards development, and identifies strategies to advance Canadian standardization efforts.

Accreditation services are provided by SCC to various customers, including product certifiers, testing laboratories, and standards development organizations. A list of SCC programs and accredited bodies is publicly available at www.scc.ca.

Document Was Downloaded By Marco Stucchi For Use By ABB INC Stucchi, Marco : 5/4/2026 - 5:36 AM

UL Standard for Safety for Software Cybersecurity for Network-Connectable Products, Part 2-1: Particular Requirements for Network Connectable Components of Healthcare and Wellness Systems, ANSI/CAN/UL 2900-2-1

First Edition, Dated September 1, 2017

Summary of Topics

This revision for ANSI/CAN/UL 2900-2-1, dated September 21, 2023, includes the following changes in requirements:

– Updates to UL 2900-2-1 Based on Changes to UL 2900-1; [12.1.3](#), [12.2.1](#), [12.4.3.3](#), Section [13](#), Section [13A](#), [16.12](#), [17.1](#), Section [18](#), [19.2](#), [19.3](#), [20.4.1](#) and Annex [A](#)

Text that has been changed in any manner or impacted by ULSE's electronic publishing system is marked with a vertical line in the margin.

The new and revised requirements are substantially in accordance with Proposal(s) on this subject dated June 16, 2023.

All rights reserved. No part of this publication may be reproduced, stored in a retrieval system, or transmitted in any form by any means, electronic, mechanical photocopying, recording, or otherwise without prior permission of ULSE Inc. (ULSE).

ULSE provides this Standard "as is" without warranty of any kind, either expressed or implied, including but not limited to, the implied warranties of merchantability or fitness for any purpose.

In no event will ULSE be liable for any special, incidental, consequential, indirect or similar damages, including loss of profits, lost savings, loss of data, or any other damages arising out of the use of or the inability to use this Standard, even if ULSE or an authorized ULSE representative has been advised of the possibility of such damage. In no event shall ULSE's liability for any damage ever exceed the price paid for this Standard, regardless of the form of the claim.

Users of the electronic versions of UL's Standards for Safety agree to defend, indemnify, and hold ULSE harmless from and against any loss, expense, liability, damage, claim, or judgment (including reasonable attorney's fees) resulting from any error or deviation introduced while purchaser is storing an electronic Standard on the purchaser's computer system.

No Text on This Page

Document Was Downloaded By Marco Stucchi For Use By ABB INC Stucchi, Marco : 5/4/2026 - 5:36 AM



ANSI/UL 2900-2-1-2023



SEPTEMBER 1, 2017

(Title Page Reprinted: September 21, 2023)

1

ANSI/CAN/UL 2900-2-1:2023A

**Software Cybersecurity for Network-Connectable Products, Part 2-1:
Particular Requirements for Network Connectable Components of
Healthcare and Wellness Systems**

First Edition

September 1, 2017

This ANSI/UL Standard for Safety consists of the First Edition including revisions through September 21, 2023.

The most recent designation of ANSI/UL 2900-2-1 as an American National Standard (ANSI) occurred on September 21, 2023. ANSI approval for a standard does not include the Cover Page, Transmittal Pages, Title Page, Preface or SCC Foreword.

This standard has been designated as a National Standard of Canada (NSC) on September 21, 2023.

COPYRIGHT © 2023 ULSE INC.

Document Was Downloaded By Marco Stucchi For Use By ABB INC Stucchi, Marco : 5/4/2026 - 5:36 AM

No Text on This Page

Document Was Downloaded By Marco Stucchi For Use By ABB INC Stucchi, Marco : 5/4/2026 - 5:36 AM

CONTENTS

Preface	5
---------------	---

INTRODUCTION

1 Scope	7
2 Normative References	7
2A Informative References	7
3 Glossary	8

DOCUMENTATION FOR PRODUCT, PROCESSES, AND USE

4 Product Documentation	8
5 Process Documentation	9
6 Documentation for Product Use	9
6.1 Safety-related security considerations for product use	9
6.2 Instructions	9

SECURITY CONTROLS

7 General	9
8 Access Control, User Authentication, and User Authorization	9
9 Remote Communication	9
10 Cryptography	10
11 Product Management	10

PRODUCT ASSESSMENT

12 Safety-Related Security Risk Management	10
12.1 Risk analysis	10
12.2 Risk evaluation	11
12.3 Risk control	11
12.4 Coverage of security analysis and testing	12
13 Known Vulnerability Testing	14
13A Software Composition Analysis	15
14 Malware Testing	15
15 Malformed Input Testing	15
16 Structured Penetration Testing	15
17 Software Weakness Analysis	16
18 Static Source Code Analysis	16
19 Static Binary and Bytecode Analysis	16

ORGANIZATIONAL ASSESSMENT

20 Lifecycle Security Processes	17
20.1 Quality management processes	17
20.2 General procurement processes	17
20.3 Procurement risk management process	17
20.4 Product update release and patch management process	18
20.5 Decommissioning process	18
20.6 Packaging and shipment	18

ANNEX A (Informative) – Rationale for the Requirements

No Text on This Page

Document Was Downloaded By Marco Stucchi For Use By ABB INC Stucchi, Marco : 5/4/2026 - 5:36 AM

Preface

This is the First Edition of the ANSI/CAN/UL 2900-2-1, Standard for Software Cybersecurity for Network-Connectable Products, Part 2-1: Particular Requirements for Network Connectable Components of Healthcare and Wellness Systems.

ULSE is accredited by the American National Standards Institute (ANSI) and the Standards Council of Canada (SCC) as a Standards Development Organization (SDO).

This Standard has been developed in compliance with the requirements of ANSI and SCC for accreditation of a Standards Development Organization.

This ANSI/CAN/UL 2900-2-1 Standard is under continuous maintenance, whereby each revision is approved in compliance with the requirements of ANSI and SCC for accreditation of a Standards Development Organization. In the event that no revisions are issued for a period of four years from the date of publication, action to revise, reaffirm, or withdraw the standard shall be initiated.

In Canada, there are two official languages, English and French. All safety warnings must be in French and English. Attention is drawn to the possibility that some Canadian authorities may require additional markings and/or installation instructions to be in both official languages.

Only metric SI units of measurement are used in this Standard. If a value for measurement is followed by a value in other units in parentheses, the second value may be approximate. The first stated value is the requirement.

Comments or proposals for revisions on any part of the Standard may be submitted to UL at any time. Proposals should be submitted via a Proposal Request in UL's On-Line Collaborative Standards Development System (CSDS) at <http://csds.ul.com>.

Our Standards for Safety are copyrighted by ULSE Inc. Neither a printed nor electronic copy of a Standard should be altered in any way. All of our Standards and all copyrights, ownerships, and rights regarding those Standards shall remain the sole and exclusive property of ULSE Inc.

This Edition of the Standard has been formally approved by the Technical Committee (TC) on Software Cybersecurity for Components of Healthcare Systems, TC 2900-2-1.

This list represents the TC 2900-2-1 membership when the final text in this standard was balloted. Since that time, changes in the membership may have occurred.

TC 2900-2-1 Membership

Name	Representing	Interest Category	Region
Ahmadi, Mike	M Ahmadi	General	USA
Alvarez, Edison	Becton Dickinson	Producer	USA
Barker, David	D Barker	General	USA
Biggs, Doug	UL Solutions	Testing & Stds Org	USA
Callahan, Haley	UL Standards & Engagement	TC Project Manager – Non-voting	USA
Chimalakonda, Sridhar	Indian Institute of Technology Tirupati	General	India

TC 2900-2-1 Membership Continued on Next Page

ULSE INC. COPYRIGHTED MATERIAL – NOT AUTHORIZED FOR FURTHER REPRODUCTION OR DISTRIBUTION WITHOUT PERMISSION FROM ULSE INC.

TC 2900-2-1 Membership Continued

Name	Representing	Interest Category	Region
Cosman, Eric	OIT Concepts LLC	Non-voting member	USA
Dawson, Joe	EWA-Canada (an Intertek Co.)	Testing & Stds Org	Newfoundland, Canada
Dischert, Larry	Johnson Controls, Inc./ Building Solutions North America	Commercial/Industrial User	USA
Fields, Jennifer	UL Standards & Engagement	TC Chair – Non-voting	USA
Finnegan, Anita	NOVA LEAH	Supply Chain	Ireland
Fitzgerald, Brian	Food & Drug Administration	Government	USA
Fogleman, Greg	Department of Veterans Affairs	Government	USA
Francois, Guy	Sekon Enterprise	General	USA
Fuchs, Kenneth	Draeger Medical Systems, Inc	Producer	USA
Garrett, Michael	Garrett Technologies Inc	General	USA
Glasgow, Ian	Health Canada	Government	Ontario, Canada
Goldman, Julian	Massachusetts General Hospital	Consumer	USA
Griffith, Steve	NEMA	Non-voting member	USA
Ivey, James	Tektone Sound & Signal Mfg Inc	Producer	USA
Lee, Simon	CPSC	Non-voting member	USA
Leinonen, Juuso	ECRI	Supply Chain	USA
Li, Xiaodong	Lenovo (Beijing) Ltd	Producer	China
Lubadel, Joern	B Braun Medical Inc	Producer	USA
Martin, Robert	The Mitre Corporation	Commercial / Industrial User	USA
Rowland, Michael	IAEA	Government	Austria
Sharp, Neil	Austco Healthcare	Producer	USA
Shkolnik, Moti	Firedome	Supply Chain	USA
Srivathsa, Karthik	Rauland-Borg Corp	Producer	USA
Tran, Phat	BC Safety Authority	Non-voting member	British Columbia, Canada
Vance, Matthew	HCA Healthcare Inc	Commercial / Industrial User	USA
Vasserman, Eugene	Kansas State University	General	USA
Wang, Hui	CNCERT/CC	General	China

International Classification for Standards (ICS): 35.030, 35.110, 35.240.50, 35.240.80

For information on ULSE Standards, visit <http://www.shopulstandards.com>, call toll free 1-888-853-3503 or email us at ClientService@shopULStandards.com.

This Standard is intended to be used for conformity assessment.

The intended primary application of this standard is stated in its scope. It is important to note that it remains the responsibility of the user of the standard to judge its suitability for this particular application.

CETTE NORME NATIONALE DU CANADA EST DISPONIBLE EN VERSIONS FRANÇAISE ET ANGLAISE

INTRODUCTION

NOTE: This Standard for Software Cybersecurity for Network-Connectable Products, Part 2-1: Particular Requirements for Network Connectable Components of Healthcare and Wellness Systems, is to be used in conjunction with the Standard for Software Cybersecurity for Network-Connectable Products, Part 1: General Requirements, UL 2900-1. The requirements for network connectable components of healthcare systems are contained in this part 2 standard and UL 2900-1. Requirements of this Part 2 standard, where stated, amend the requirements of UL 2900-1. Where a particular subclause of UL 2900-1 is not mentioned in UL 2900-2-1, the UL 2900-1 subclause applies. This standard has been developed in accordance with IEC Guide 120, Security aspects – Guidelines for their inclusion in publications.

1 Scope

1.1 This security evaluation standard applies to the testing of network connectable components of healthcare systems. It applies to, but is not limited to, the following key components:

- a) Medical devices;
- b) Accessories to medical devices;
- c) Medical device data systems;
- d) In vitro diagnostic devices;
- e) Health information technology;
- f) Wellness devices; and
- g) All software components used for the secure operation of the device, wherever they may reside, including remote assets.

Note – Combinations of the technologies listed here may be applied to such solutions as “telemedicine,” where a single solution may contain both regulated and unregulated components.

2 Normative References

2.1 The Standard for Software Cybersecurity for Network-Connectable Products, Part 1: General Requirements, UL 2900-1, shall be applied as specified in this standard.

2.2 The Standard for Medical Devices – Application of Risk Management to Medical Devices, ISO 14971:2007, shall be applied as specified in this standard.

2.3 The Standard for Medical Devices – Quality Management Systems – Requirements for Regulatory Purposes, ISO 13485:2003, shall be applied as specified in this standard.

2.4 The Standard for Medical Device Software – Software Life Cycle Processes, IEC 62304:2006+AMD1:2015, shall be applied as specified in this standard.

2.5 The Standard for Health software – Part 1: General requirements for product safety, IEC 82304-1:2016

2A Informative References

AAMI TIR57, Principles For Medical Device Security – Risk Management (2016)

AAMI TIR75, Factors to Consider When Multi-Vendor Devices Interact Via an Electronic Interface: Practical Applications and Examples (2019)

AAMI/UL 2800-1, Medical Device Interoperability

ANSI/NEMA HN 1-2019, Manufacturer Disclosure Statement for Medical Device Security

IEC/TR 80001-2-8:2016, Application of risk management for IT-networks incorporating medical devices – Part 2-8: Application guidance – Guidance on standards for establishing the security capabilities identified in IEC 80001-2-2

IEC TR 80001-2-9:2017, Application of risk management for IT-networks incorporating medical devices – Part 2-9: Application guidance – Guidance for use of security assurance cases to demonstrate confidence in IEC/TR 80001-2-2 security capabilities

IEC/TR 60601-4-1:2017, Medical electrical equipment – Part 4-1: Guidance and interpretation – Medical electrical equipment and medical electrical systems employing a degree of autonomy

IEEE/UL DTSec, Standard for Wireless Diabetes Device Security (DTSec)

IEEE/UL DTMoST, Diabetes Technology Society Mobile Platform Controlling a Diabetes Device Security and Safety Standard

ISO/IEC 15408-1:2009, Information technology – Security techniques – Evaluation criteria for IT security – Part 1: Introduction and general model

MEDICAL DEVICE AND HEALTH IT JOINT SECURITY PLAN;
<https://healthsectorcouncil.org/wp-content/uploads/2019/02/HSCC-MEDTECH-JSP-v1.2.pdf>

3 Glossary

3.1 BASIC SAFETY – Freedom from unacceptable risk, for those risks that are not directly related to the intended use of the product.

3.2 ESSENTIAL PERFORMANCE – Performance, other than that related to BASIC SAFETY, whose loss or degradation beyond the limits specified by the MANUFACTURER results in an unacceptable risk. [IEC 60601-1 Ed3.1]

3.3 MANUFACTURER – See VENDOR

3.4 RISK MANAGEMENT FILE – Set of records and other documents that are produced by risk management [EN ISO 14971: 2012]

DOCUMENTATION FOR PRODUCT, PROCESSES, AND USE

4 Product Documentation

4.1 Product documentation shall meet the requirements of the Standard for Software Cybersecurity for Network-Connectable Products, Part 1: General Requirements, UL 2900-1, except as noted in this standard.

5 Process Documentation

5.1 Process documentation shall meet the requirements of the Standard for Software Cybersecurity for Network-Connectable Products, Part 1: General Requirements, UL 2900-1, except as noted in this standard.

6 Documentation for Product Use

6.1 Safety-related security considerations for product use

6.1.1 Intended use of the product as indicated in the Risk Management File (RMF)

6.1.1.1 A statement of the product's intended use shall be included in the Risk Management File.

6.1.1.2 Jurisdiction-specific definitions for 'intended use' and 'indications for use' shall be provided in the Risk Management File.

6.1.1.3 The product's intended use statement shall indicate essential performance that may be impacted by security breach.

6.1.2 Environment in which the product is intended to be used

6.1.2.1 The product's assumptions regarding the environment within which it is intended to be operated shall be enumerated.

6.1.2.2 The product's indications for use statement shall identify security capabilities and constraints relative to assumptions regarding the environment within which it is intended to be operated.

6.2 Instructions

6.2.1 Instructions on means to over-ride security measures when necessary for patient safety per [12.4.1.7](#) and [12.4.2.6](#) shall be communicated to intended stakeholders with security controls as described in the Risk Management File.

SECURITY CONTROLS

7 General

7.1 The product shall comply with the requirements of the Standard for Software Cybersecurity for Network-Connectable Devices, Part 1: General Requirements, UL 2900-1, Section 7, except as noted in this standard.

8 Access Control, User Authentication, and User Authorization

8.1 The product shall comply with the requirements of the Standard for Software Cybersecurity for Network-Connectable Devices, Part 1: General Requirements, UL 2900-1, Section 8, except as noted in this standard.

9 Remote Communication

9.1 The product shall comply with the remote communication requirements of the Standard for Software Cybersecurity for Network-Connectable Devices, Part 1: General Requirements, UL 2900-1, Section 9, except as noted in this standard.

10 Cryptography

10.1 The product shall comply with the cryptography requirements of the Standard for Software Cybersecurity for Network-Connectable Devices, Part 1: General Requirements, UL 2900-1, Section 10, except as noted in this standard.

11 Product Management

11.1 The product shall comply with the product management requirements of the Standard for Software Cybersecurity for Network-Connectable Devices, Part 1: General Requirements, UL 2900-1, Section 11, except as noted in this standard.

PRODUCT ASSESSMENT

12 Safety-Related Security Risk Management

12.1 Risk analysis

12.1.1 The product shall comply with the applicable requirements of the Standard for Medical Devices – Application of Risk Management to Medical Devices, ISO 14971, or the Standard for Software Cybersecurity for Network-Connectable Products, Part 1: General Requirements, UL 2900-1, Section 12, Vendor Product Risk Management Process.

NOTE 1: Information Technology network risks per the Standard for Application of Risk Management for IT-Networks Incorporating Medical Devices – Part 1: Roles, Responsibilities and Activities, IEC 80001-1, should be considered as part of product risk management.

NOTE 2: Threat Modeling should be performed following the principles of AAMI TIR 57 to generate an abstracted representation of the product / system that is to be decomposed into the components listed in a Software Bill of Materials (SBOM). The threat model should identify assets, attack surfaces, vulnerabilities, attack vectors, risk controls, and residual risk in the context of objects, processes, interfaces, dataflows, and trust boundaries within specific use environments and use cases. The level of threat modeling detail should align with the component decomposition granularity provided by Software Composition Analysis.

12.1.2 A risk management file shall be constructed in accordance with the Standard for Medical Devices – Application of Risk Management to Medical Devices, ISO 14971, risk management process, or equivalent, and it shall specifically include the following elements with regard to security:

a) Security risk analysis;

NOTE: The security risk analysis should consider defense-in-depth also known as layer of protection analysis (LOPA)¹.

b) Security risk evaluation;

c) Security risk control;

NOTE: Security risk controls should consider a defense-in-depth strategy to minimize impact of a breach.

d) Production and post-production changes in security risks that may change over time;

NOTE: See also the post market surveillance requirements of ISO 13485, ISO 14971, TIR57 and [20.4](#).

e) Verification and validation of security risk controls; and

NOTE: Validation demonstrates that the specification and resulting implementation satisfies user needs through acceptance and suitability testing.

f) Analysis of the acceptability of residual security risk.

¹ See the IEC 61511, Functional Safety – Safety Instrumented Systems for the Process Industry Sector standards.

12.1.3 Processes for Quality Management (QM) shall reflect:

- a) Allocation of adequate security resources to product development;

NOTE: Compliance can be determined by demonstrating compliance with Clauses [13A](#) – [20](#) of this standard.

- b) Establishing policies and criteria for security risk acceptability for the product based on applicable international, national or regional regulations; and
- c) Ongoing re-assessment of the continued suitability of the security risk management process at planned intervals, including documentation of decisions and actions taken.

12.2 Risk evaluation

12.2.1 The risk evaluation shall be conducted in accordance with 12.3 in the Standard for Software Cybersecurity for Network-Connectable Products, Part 1: General Requirements, UL 2900-1.

12.3 Risk control

12.3.1 The risk controls identified in Sections 7 – 11 of the Standard for Software Cybersecurity for Network-Connectable Products, Part 1: General Requirements, UL 2900-1, and the security capabilities of the Application of Risk Management for IT-Networks Incorporating Medical Devices – Part 2-2: Guidance for the Disclosure and Communication of Medical Device Security Needs, Risks and Controls, IEC/TR 80001-2-2, or equivalent, shall be considered for risk management.

12.3.2 Any security measures contraindicated by the risk analysis are to be designated as Not Applicable (NA) with justification(s) in the Risk Management File or explanation of alternative measures.

12.3.3 A security risk management plan shall be constructed and documented to reflect the following processes, including rationale for any qualitative or quantitative measures used:

- a) Identification of assets, threats, and vulnerabilities;
- b) Assessment of the impact of threats and vulnerabilities on device functionality and end users/patients;
- c) Assessment of the likelihood of a threat and of a vulnerability being exploited;
- d) Determination of risk levels and suitable mitigation strategies; and
- e) Assessment of residual risk and risk acceptance criteria.
- f) Security-relevant data logging when applicable

12.3.4 The vendor shall provide a risk management artifact to reflect hazard analysis, mitigations, and design considerations pertaining to intentional and unintentional cybersecurity risks associated with the product, including:

- a) A specific list of all cybersecurity risks that were considered in the design of the product;
- b) A specific list and justification for all cybersecurity risk controls that were established for the product;
- c) A means of demonstrating traceability that links product cybersecurity risk controls to the cybersecurity risks that were considered;

d) A summary describing the plan for providing validated software updates and patches as needed throughout the lifecycle of the product to continue to assure its safety and effectiveness;

e) A summary describing cybersecurity risk controls that are in place to assure that the product software will maintain its integrity (e.g. remain free of malware) from the point of origin to the point at which that product leaves the control of the vendor; and

f) Product instructions for use and product specifications related to recommended cybersecurity risk controls appropriate for the intended use environment (e.g. anti-virus software, use of firewall).

12.3.5 The organization shall identify all security-related safety and non-safety security-related requirements for the product in the risk management file or in separate documents referenced by the risk management file (see also [12.4.1.1](#), [12.4.2.1](#), and [12.4.3.1](#)).

12.3.6 The security risk controls shall be based on requirements derived from the risk evaluation.

12.3.7 The security risk controls shall be derived from relevant product requirements including requirements not stated by the customer, but necessary for the security and safety of the product during its intended use.

12.4 Coverage of security analysis and testing

12.4.1 Protection of inputs

12.4.1.1 Security measures protecting inputs to the product shall be specified when applicable (e.g. encryption of input data).

12.4.1.2 Any specific inputs to the risk controls derived from the product inputs shall be specified (e.g. threshold values for safety interlocks).

12.4.1.3 Data security (e.g. authenticated encryption) shall be specified for inputs.

12.4.1.4 Metadata security comparable to that in [12.4.1.3](#) shall be specified for inputs (e.g. patient identifying information).

12.4.1.5 Security measures to protect confidentiality of the contextual meaning of any exposed input data (e.g. wirelessly transmitted data as opposed to data securely entered locally at an HMI) shall be specified.

NOTE: An example of such a measure would be de-identification of patient identifiable data.

12.4.1.6 Security measures protecting assets against transitional vulnerabilities exploited through input manipulation during product state changes shall be specified (e.g. exception handling for out-of-range values, see SANS top 25).

NOTE: Triggers for state machine changes should be considered.

12.4.1.7 Secured means to over-ride input security measures (e.g. "break-the-glass") when necessary for patient safety shall be specified.

12.4.1.8 All security-relevant assumptions and constraints, related to the product inputs, imposed during the development of the product shall be specified.

12.4.2 Protection of outputs

12.4.2.1 Security measures protecting outputs of the product shall be specified.

12.4.2.2 Data security (e.g. encryption) shall be specified for outputs.

12.4.2.3 Metadata security shall be specified for outputs.

12.4.2.4 Security measures to protect confidentiality, integrity, and availability of the contextual meaning of any exposed output data (e.g. wirelessly transmitted data) shall be specified.

NOTE: An example of such a measure would be de-identification of patient identifiable data.

12.4.2.5 Security measures protecting assets against transitional vulnerabilities exploited through output manipulation (e.g. falsification of security credentials) during product state changes shall be specified.

12.4.2.6 Secured means to over-ride output security measures (e.g. “break-the-glass”) when necessary for patient safety shall be specified.

12.4.2.7 All security-relevant assumptions and constraints, related to the product output(s), imposed during the development of the product shall be specified.

12.4.3 Design and Development Process-related Risk Controls

NOTE: Compliance is to be determined by inspection of the risk management file.

12.4.3.1 Security controls shall be implemented during the design and development process as required by the risk assessment, where the following subclauses ([12.4.3.2](#) – [12.4.3.20](#)) constitute a minimum set of design and development process security controls to be considered, with the nonuse of any of these considerations justified in the Risk Management File.

12.4.3.2 “Random” number seeds shall be evaluated during design for suitability per the security risk assessment and documented in the Risk Management File.

12.4.3.3 Software processes and their authorized users shall be granted only those privileges required for them to carry out their specified function(s). See UL 2900-1, Clause 8.7.

12.4.3.4 Unless contraindicated by the product risk assessment, all inputs shall be validated prior to being processed.

12.4.3.5 Where such constraints do not introduce new hazards, programs shall be deterministically constrained (i.e. use of programming constructs controlled) to avoid vulnerabilities including, but not limited to:

- a) Buffer overflow;
- b) Use of undefined or uninitialized programming constructs (e.g. null pointer dereference);
- c) Use of unmanaged resources (e.g. use after free);
- d) Use of uninitialized memory; and
- e) Improper use of resource management functions (e.g. illegal free of an already freed pointer or improper use of buffered data).

f) Use of exception handling techniques with catch-all implementation that allows exceptions to arise through the call stack without affecting the core functionality of the device, if possible, or with documented fallback functionality in the case it is affected by exceptions.

12.4.3.6 The use of memory safe languages shall be considered during risk assessment.

12.4.3.7 The use of language subsetting shall be considered during risk assessment.

12.4.3.8 The use of automated memory safety error mitigation and compiler-enforced buffer overflow elimination shall be considered during risk assessment.

12.4.3.9 The use of secure coding standards shall be considered during risk assessment.

12.4.3.10 The use of automated thread safety analysis shall be considered during risk assessment.

12.4.3.11 The use of proven cryptographic algorithms and implementations shall be considered during risk assessment.

12.4.3.12 The use of modified condition decision coverage for functional testing shall be considered during risk assessment and test planning.

12.4.3.13 Unused functions/features shall be removed based on analysis of operational use cases and if deemed necessary not to be removed, the presence of such unused functions shall be justified in the Risk Management File.

12.4.3.14 Digitally signed software and firmware shall be used.

12.4.3.15 Software and firmware updates shall be validated using digital signatures prior to re-initiation of the product.

12.4.3.16 An allow-list shall be used to ensure only authorized software is executed unless such use introduces new hazards.

12.4.3.17 Proactive endpoint malware protection shall be used when technically feasible (e.g. a list of permitted processes/ports). Reactive malware protection (e.g. antivirus, intrusion detection) shall be used when proactive protection is not feasible. If no tool or method is available for endpoint protection, this should be captured in the risk assessment and documented accordingly.

NOTE: See [12.4.3.16](#).

12.4.3.18 Storage (e.g. memory) shall be monitored with an integrity monitor to ensure that the code and data sections are not unintentionally modified.

12.4.3.19 Software (including sensitive data) interfacing directly to hardware shall be protected against unauthorized modifications or access via either software or hardware means as prescribed by the manufacturer's risk management process.

12.4.3.20 The use of perfect-forward secrecy in the encryption protocol shall be considered during risk assessment.

13 Known Vulnerability Testing

13.1 Deleted

13.2 Deleted

13.3 Deleted

13A Software Composition Analysis

13A.1 The product shall be tested in accordance with the Standard for Software Cybersecurity for Network-Connectable Products, Part 1: General Requirements, UL 2900-1, Section 13A.

14 Malware Testing

14.1 The product shall be tested for malware in accordance with the Standard for Software Cybersecurity for Network-Connectable Products, Part 1: General Requirements, UL 2900-1, Section 14.

15 Malformed Input Testing

15.1 The product shall undergo malformed input testing in accordance with the Standard for Software Cybersecurity for Network-Connectable Products, Part 1: General Requirements, UL 2900-1, Section 15, to identify unknown vulnerabilities within the defined testing parameters and in accordance with [12.3.5](#) through [12.4.1.8](#) of this standard.

Note: Malformed input testing is also known in the industry as fuzz testing.

15.2 Upon conducting the Malformed Input Testing and Structured Penetration Testing according to Sections 15 and 16 of the Standard for Software Cybersecurity for Network-Connectable Products, Part 1: General Requirements, UL 2900-1, the product shall continue normal operation, per its intended use, or transition to a defined risks addressed (RA) state, as specified in the product Risk Management File (RMF).

16 Structured Penetration Testing

16.1 During the Structured White-box Penetration Testing of the Standard for Software Cybersecurity for Network-Connectable Products, Part 1: General Requirements, UL 2900-1, Section 16, the product shall be assessed for unauthorized use via the potential for Elevation of Privilege (EoP) under the specified testing conditions.

16.2 Protection against EoP shall be tested by targeting inputs, and output characteristics of the product (i.e. structured penetration testing) per [12.4.1.1](#) through [12.4.2.1](#) of this standard.

16.3 Protection against EoP shall be evaluated for software processes that may not be directly accessible via external interfaces. This shall be determined through the evaluation of [16.4](#) through [16.12](#) using the structured penetration testing approaches specified in Section 16 of the Standard for Software Cybersecurity for Network-Connectable Products, Part 1: General Requirements, UL 2900-1.

16.4 Security measures protecting the product's internal safety-critical software processes (e.g. logic and state transitions) shall be tested (i.e. for software-to-software interfaces).

16.5 Any safety-related and security-related software processes within the product affected by outputs from other software processes within the product shall be tested.

16.6 Data security (e.g. encryption) shall be tested to evaluate software processes within the product that may interact with other unsecured software processes within the product (e.g. multicore processing).

16.7 As an alternative to [16.6](#), such interactions may be viewed as inputs to the secured process per [12.4.1.1](#).

16.8 Metadata security shall be tested to evaluate software processes within the product that may interact with other unsecured software processes within the product (e.g. multicore processing).

16.9 Security measures to protect confidentiality of the contextual meaning of any exposed input data (e.g. shared between secured and unsecured cores) shall be tested to evaluate software processes within the product that may interact with other unsecured software processes within the product (e.g. multicore processing).

NOTE: An example of such a measure would be de-identification of patient identifiable data.

16.10 Security measures protecting assets against transitional vulnerabilities exploited through software process manipulation during product state changes shall be tested.

16.11 Means to over-ride software process security measures internal to the product when necessary for patient safety shall be tested.

16.12 Upon conducting the Structured Penetration Testing of Section [16](#) of the Standard for Software Cybersecurity for Network-Connectable Products, Part 1: General Requirements, UL 2900-1, the product shall continue normal operation, per its intended use, or transition to a defined Risks Addressed (RA) state, as specified in the product Risk Management File (RMF) with no EoP.

17 Software Weakness Analysis

17.1 The product shall undergo software weakness analysis per Section 17 of the Standard for Software Cybersecurity for Network-Connectable Products, Part 1: General Requirements, UL 2900-1.

17.2 The product shall contain no known weaknesses unless otherwise stated in the vendor's risk management file and also satisfying the CWSS score established as part of the risk management process.

18 Static Source Code Analysis

18.1 *Deleted*

19 Static Binary and Bytecode Analysis

19.1 The product shall comply with the Standard for Software Cybersecurity for Network-Connectable Products, Part 1: General Requirements, UL 2900-1, Section 19.

19.2 The product shall contain no known vulnerabilities unless otherwise stated in the vendor's risk management file, based on CVSS metrics or adaptation of CVSS metrics or equivalent, used in the vendor's risk management process.

19.3 The vendor's process for handling security related vulnerability reports shall be documented.

ORGANIZATIONAL ASSESSMENT

20 Lifecycle Security Processes

20.1 Quality management processes

20.1.1 The product shall be developed under a Quality Management System per the Standard for Medical Devices – Quality Management Systems – Requirements for Regulatory Purposes, ISO 13485, or equivalent.

20.1.2 The software development lifecycle shall comply with the applicable requirements of the Standard for Medical Device Software – Software Life Cycle Processes, IEC 62304, or equivalent.

20.2 General procurement processes

NOTE: Compliance is to be determined by inspection of the Risk Management File.

20.2.1 For software components integrated into the product, the vendor's Quality Management System shall address security considerations in the procurement process.

20.2.2 For components to be integrated into the product, the vendor (i.e. product developer) shall establish documented procurement procedures that include review of supplier security specifications for compatibility with organizational security policies and procedures.

20.2.3 The vendor (i.e. product developer) shall plan the supplier selection, establish selection, evaluation and re-evaluation criteria, and establish a supplier qualification process based on the supplier's ability to address defined security criteria and provide products that satisfy the vendor's security requirements.

20.2.4 The vendor (i.e. product developer) shall perform ongoing surveillance of the supplier's compliance to the security requirements. The vendor (i.e. product developer) shall also:

- a) Perform periodic requalification of the supplier, as appropriate per this surveillance; and
- b) Manage software updates (e.g. patches) as part of the ongoing supplier surveillance.

20.3 Procurement risk management process

20.3.1 The supplier shall comply with the requirements of Section [12](#), Safety-Related Security Risk Management.

20.3.2 Where contractual constraints or IP considerations preclude the disclosure of the items in Section [12](#), Safety-Related Security Risk Management, directly to the vendor (i.e. product developer), demonstrated conformance to this standard may be used instead.

20.3.3 The vendor (i.e. product developer) shall document the vendor's defined end-of life and communicate to the customer that supplier support for security aspects of the component will be provided only until the product's expected end-of-life.

20.3.4 As an alternative to [20.3.3](#), the vendor (i.e. product developer) shall demonstrate the ability to address ongoing component security without supplier support.

NOTE: An example would be compensating controls that are part of a defense-in-depth security strategy.

20.3.5 Software development tool chains shall be considered as part of purchasing controls of the quality management system.

20.4 Product update release and patch management process

20.4.1 The product shall comply with the requirements of the Standard for Software Cybersecurity for Network-Connectable Products, Part 1: General Requirements, UL 2900-1, Clause 11, Product Management.

20.4.2 Patches and fixes shall be deployed to the affected populations within 14 days of the validated fix and the manufacturer's infrastructure shall permit this.

20.5 Decommissioning process

20.5.1 For products intended to be part of a larger system, decommissioning procedures shall be provided to allow for the product to be removed from the system (and replaced if performing a security-critical function) without compromising system security during the product decommissioning process.

NOTE: A compromise of system security would be, for example, leaks of PHI / PII from the overall system whether via communication channels or improper disposal of a system component.

20.6 Packaging and shipment

20.6.1 The product packaging and distribution processes shall maintain the integrity of the security measures specified in Section 5, Process Documentation, using techniques of [12.4.3.5](#) or [12.4.3.16](#) or equivalent, unless contraindicated by the risk management process.

20.6.2 The measures employed shall be described in the Risk Management File.

ANNEX A (Informative) – Rationale for the Requirements

A1.1 This Annex provides informative documentation on how a clause is intended to operate and rationale for inclusion of the clause in the standard.

Table A1.1
Rationale for the Requirements

Reference	Description	Rationale
6.1.1.1	A statement of the product's intended use is included in the Risk Management File	Safety related security considerations for product use should be aligned with intended use considered in the relevant Risk Management File (RMF). A product may have multiple intended uses, which should be included in the RMF. Further, as noted in ISO 14971:2012, the intended use shall be documented and maintained in the RMF. Documentation of the intended use allows the manufacturer to identify and document relevant qualitative and quantitative characteristics that could affect the safety of a medical device. An RMF is not a discrete or singular document, but rather any documentation that describes the mitigation of product risk.
6.1.1.2	Jurisdiction-specific definitions for 'intended use' and 'indications for use' are provided in the Risk Management File	Product sold into multiple jurisdictions may have differing intended uses and indications for use due to limitations imposed by regulators or payors. Further, the differences may include new risks or different risk levels. Therefore, in conjunction with the rationale listed for 6.1.1.1 , jurisdiction-specific definitions for intended use and indications for use must be considered in the RMF.
6.1.1.3	Essential performance that may be impacted by a security breach is documented in the product's intended use statement	Essential performance of a device may be affected by a breach. Further, in accordance with IEC 60601-1, essential performance must be maintained during both normal operation and failure of any one component. Thus, it is important to identify in the intended use statement how essential performance could be impacted by a security breach. Notably – while IEC 60601-1 defines and incorporates the concept of essential performance, this is not a defined term, but could be aligned with the functional safety concept in IEC 61010-1.
6.1.2.1	Assumptions regarding the environment in which product is intended to be operated are documented	The product's environment, may increase or decrease the potential for certain types of cybersecurity breaches. If the product is intended to be used on a network with robust cybersecurity controls, the potential for cybersecurity breaches could be decreased. Assumptions one way or another must be defined so that end uses/facilities know that they are expected to apply controls.
6.1.2.2	Security capabilities and constraints relative to assumptions regarding environment within which it is intended to be operated are identified	Similar to the safety-related security considerations in 6.1.1.3 and the assumptions rationale provided for 6.1.2.1 , the product user should be made aware of the intended product environment so that they can assess and, if warranted, implement additional cybersecurity safeguards. Further, the user should be made aware of how security capabilities and constraints impact the product's intended use, and more specifically, the essential performance. The threat model should be driven by the threat environment.
6.2.1	Instructions on means to over-ride security measures when necessary for patient safety shall be communicated to intended stakeholders with security controls as described in the Risk Management File	For all safety/patient critical functions of the device, a mechanism must be in place to override security measures of the device in order to be able to deliver time critical patient care, e.g. such as during an emergency. Instructions on secured means to override the input and output security measures should be

Table A1.1 Continued on Next Page

Table A1.1 Continued

Reference	Description	Rationale
		prepared and documented in advance because the existence of the security measure could lead to the deterioration of patient safety, for example, in case a clinician is not able to deliver time critical patient care.
12.1.2	A compliant Risk Management File exists	Risk management processes should be documented as the risk management file following ISO 14971 or similar risk management standards. They should consider not only safety but also security. Some important elements which should be included in the risk management file are listed in terms of security risk management.
12.1.3(a)	QM processes reflect allocation of adequate security resources to product development	Cybersecurity shall be considered as early as possible in the product development process to mitigate cybersecurity risks. The normative reference to ISO 13485 provides for top management commitment, which in turn drives adequate implementation resources. Insight applied at the earliest point possible in the product development process can avoid wasteful rework, the need for last minute fixes to remove known types of flaws and mistakes, and minimize the number of post-deployment fixes for quality escapes that impact reliability, safety, and security.
12.1.3(b)	QM processes establish policies and criteria for security risk acceptability for the product based on applicable international, national or regional regulations	Consistent policies and criteria for decisions are needed to address the variety of impacts that errors have and to guide the identification of which errors need mitigations.
12.1.3(c)	QM processes include ongoing re-assessment of the continued suitability of the security risk management process at planned intervals, including documentation of decisions and actions taken	While the natural laws remain constant over time, the ability of software errors to cause harm or for them to be activated and manipulated by attackers can change as new techniques for influencing systems emerge and made more repeatable. Re-assessment needs to include changes in intended use and changes in use environment.
12.3.2	Risk Management File reflects assessment of security measures contraindicated by the risk analysis	Contraindication is sometimes missed in the security risk management process, but it should take priority over anything else in medical devices. Therefore alternative measures should be presented or the measure should be noted as Not Applicable or contraindicated based on situational risk context. (See AAMI TIR57.)
12.3.3	An adequate security risk management plan exist	A security risk management plan that is periodically updated is important for downstream risk management activities (See ISO 14971, AAMI TIR57 or AAMI TIR97.)
12.3.4	Vendor has performed hazard analysis, mitigations, and design considerations pertaining to intentional and unintentional cybersecurity risks associated with the product	A top level hazard and threat analysis is important to ensure system level security hazards are identified, recorded and mitigated. This should include both top down and bottom up analysis.
12.3.5	Risk management file identifies all security-related safety and non-safety requirements for the product	A version controlled repository of requirements is important to drive downstream design, verification and validation (V&V) and recovery activities.
12.3.6	Security risk controls are based on requirements derived from the risk evaluation	Cybersecurity related requirements stemming from the risk and threat evaluation phase should have corresponding risk controls.
12.3.7	Security risk controls are derived from relevant product requirements including requirements not stated by the customer, but necessary for the security and safety of the product during its intended use	Cybersecurity related requirements stemming from the review of product requirements (including those derived from regulatory guidance, industry best practices, and emerging risks) should have corresponding risk controls.
12.4.1	Protection of inputs (combine in testing protocol with UL 2900-1 15.1 & 16.1)	Inputs should not alter the intended risk profile of the device. Protection of input over communications protocols or user interfaces should include measures such as specifying appropriate data inputs and data security.

Table A1.1 Continued on Next Page

Table A1.1 Continued

Reference	Description	Rationale
		Product inputs should be considered because they could be the most accessible and exploitable for unauthenticated users. The tests on those measures may include the malformed input testing in 15.1, the structured penetration testing in 16.1 of UL 2900-1, and others as appropriate.
12.4.2	Protection of outputs (combine in testing protocol with UL 2900-1 15.1 & 16.1)	Outputs should not deviate from the intended risk profile of the device. Protection of the product output should include measures such as data security and meta data security. It should also present secured means to override output security measures. The tests on those measures should include output monitoring during the malformed input testing in 15.1, structured penetration testing in 16.1 of UL 2900-1, and others as appropriate.
12.4.3	Design and Development Process-related risk controls	Design and development process is the most effective and practical phase in the total product lifecycle to implement the security controls onto product. Security controls should be implemented based on risk and threat assessment with foundational controls listed.
12.4.3.5	Product includes reasonable constraints to avoid vulnerabilities such as	
	Buffer Overflow	A buffer overflow occurs when data being written into a buffer exceeds the size originally allocated to the buffer. While some programming languages have protections in place to detect this, many, such as C and C++ do not. In the event a buffer overflow occurs, the contents of the buffer can overwrite other application values. Attackers can use this to manipulate program execution.
	Null Pointer Dereference	When an application contains a pointer, that points to a valid data location it is considered to be a Null Pointer. In memory safe languages, such as C#, a NullPointerException will be thrown, however, languages such as C/C++ do not have this protection, leading to 'undefined behavior'. This means a program can crash, it can segfault, it can potentially access the memory space of a different application. Because of the undefined behavior it presents a security attack surface.
	Use After Free	Use after free refers to a program referencing memory that has been freed, or released from its previous variable. The risk with use after free, is that after memory has been freed it is likely reallocated to a new variable. If the old variable is then used, it is now reference memory that has taken on new ownership and likely new values. This leads to undefined behavior that can range from program crash, to execution of unexpected code, to modification of unexpected values. Because of the undefined behavior it presents a security attack surface.
	Use of Uninitialized Memory	Use of uninitialized memory occurs when a variable in code uses memory that has yet to be assigned a value. This leads to unpredictable values being used, which can lead to unintended or unpredictable results. Because of the undefined behavior it presents a security attack surface.
	Improper Use of resource management functions	Programming languages that expose resource management functions, such as the ability to allocate or free memory, present opportunities for programmers to incorrectly manage resources. For example, a pointer double free, where a free is called on a pointer that has already been freed. Errors like this cause a program's behavior to become unpredictable. In the double free

Table A1.1 Continued on Next Page

Table A1.1 Continued

Reference	Description	Rationale
		example, the second call to free will mark the memory as available, and it may now be in use by another variable leading to unknown behavior. Because of the undefined behavior it presents a security attack surface.
	Use of exception handling techniques with catch-all implementation	Exception handling routines are typically set up to gracefully handle expected exceptions. However malicious attackers or unexpected input may cause an application to fail in an unexpected way. By having 'catch-all' handlers in all exception handling routines, the application can gracefully handle all possible exceptions, even if they are unexpected. Without a 'catch-all', bad input or behavior may circumvent error handling and cause unexpected behavior in the program. Because of the undefined behavior it presents a security attack surface.
12.4.3.6	Choice of programming language (the use of memory safe languages) is considered and documented	An appropriate programming language for the type of application being developed should be carefully selected and documented. An inappropriate language may not lend itself to a good static code analysis tool and may have the potential to introduce more security bugs than others.
12.4.3.7	Choice of language subsetting is considered and documented	The language and other configurations that are used in the compiler need to be carefully chosen so as to reduce the chances of security related bugs. For example, enabling an appropriate warning level and reduced optimization have the potential to avoid security weaknesses. Also derived subsets of programming languages such as MISRA C or C++ may be considered.
12.4.3.8	The use of automated memory safety error mitigation and compiler-enforced buffer overflow elimination is considered and documented	Several compilers provide specific flags for the use of automated memory safety error mitigation and elimination of compiler-enforced buffer overflows. These improve code integrity and reduce the potential for security related bugs.
12.4.3.9	The use of secure coding standards is considered and documented	Using good coding standards enables consistent code quality which very often is a precursor to secure code development.
12.4.3.10	The use of automated thread safety analysis is considered and documented	Thread Safety Analysis is designed to prevent both race conditions and deadlock which can lead to Denial of Service and other security weaknesses. Automated static code analysis tools allow to detect potential areas where there is scope for such bugs.
12.4.3.11	The use of proven cryptographic algorithms is considered and documented	Appropriate cryptographic algorithms provide required protection through confidentiality of data as well as the basis for authenticated communication, secure update, code integrity, code signing and other key aspects of cyber security. Depending on the sensitivity of the data and functionality being accessed, appropriate cryptography (as recommended by NIST) should be used. (See also 12.4.3.18 and UL 2900-1, Appendix C – Requirements for Security Functions.)
12.4.3.12	The use of modified condition decision coverage for functional testing is considered and documented	Code quality and coverage aspects like modified condition / decision coverage (MC/DC) should be covered by code coverage/quality tools. These aspects are integral to the software development process, and should be tested in unit testing of the code. The code quality is also an important software release parameter. The software should meet the code quality/coverage requirements to clear the release. Documenting the unresolved high/critical issues in the risk file is recommended.

Table A1.1 Continued on Next Page

Table A1.1 Continued

Reference	Description	Rationale
12.4.3.13	Unused functions/features are analyzed and removed. Retention of such functions and features is documented in the risk management file	Unused code/features should be covered during requirements engineering processes as well as by Code quality tools and also is a part of the secure code analysis tools. These aspects are integral to the software development process, and should be tested in unit testing of the code. The code quality is also an important software release parameter. These aspects are typically work instructions given to the team, and also feed into the release criteria to be passed for a software release. Documenting the unresolved high/critical issues in the risk file is recommended.
12.4.3.14	All software and firmware is digitally signed	For example, the Draft "Content of Premarket Submissions for Management of Cybersecurity in Medical Devices", discusses "Where feasible, ensure that the integrity of software is validated prior to execution, e.g., permitting based on a list of allowed software digital signatures", "and "Where feasible, use industry-accepted best practices to maintain/verify integrity of code while it is being executed on the device." Firmware signing is to be designed in the security requirements and should be a part of the verification and validation process. Some potential current tools to meet this objective can be leveraged like Ncover, JCoCo, TICS, Coverity and the like for Code quality/Coverage purposes. (See also 12.4.3.18 and UL 2900-1, Appendix C – Requirements for Security Functions.)
12.4.3.15	Software and firmware updates rely on a digital signature validation prior to re-initiation of the product	For example, in the Draft "Content of Premarket Submissions for Management of Cybersecurity in Medical Devices". Its mentioned that "Only allow installation of cryptographically verified firmware / software updates. Use cryptographically signed updates to help prevent unauthorized reduction in the level of protection (downgrade or rollback attacks)". Software Updates relying on digital signatures should be designed in the security requirements and should be a part of the verification and validation process.
12.4.3.16	Only a permitted list of trusted software is allowed to execute. Exceptions are documented in risk management file	An allow-list solution is used to only allow authorized software to run on the system. In addition, the allow-list system only supports cryptographically authenticated and authorized updates.
12.4.3.17	Proactive endpoint malware protection shall be used when technically feasible	The use of software within a medical device for the detection of malware during operation of the device is desirable. However, it is recognized that certain technologies such as resource poor embedded systems may not be able to accommodate this feature. Off the shelf proactive endpoint malware protection may not be available for certain architectures or operating systems.
12.4.3.18	Storage/Memory shall be monitored for integrity	Compromising of software binary and/or data can result in an unacceptable safety risk. It is therefore important to guarantee their integrity by preventing unwanted modifications. (Note this is the method for utilizing cryptographic control over running software.)
12.4.3.19	Software interfacing directly to hardware shall be protected against unauthorized modifications or access	Particular focus shall be given to software interfacing directly to hardware as it is likely to result into an unacceptable safety risk. It is therefore important to ensure that no unwanted modification is allowed.
12.4.3.20	Use of perfect-forward secrecy in the encryption protocol shall be considered during risk assessment	Basic cryptographic protocols do not prevent future compromising of encrypted data retrieved during data exchange, for this reason perfect-forward secrecy should be used. Perfect-forward secrecy implies that data is exchanged with a unique session key which is different than the key used for data storage.

Table A1.1 Continued on Next Page

Table A1.1 Continued

Reference	Description	Rationale
14	Product passes malware testing	Malware can be introduced to the software binary/bytecode prior to its deployment on the field. It is therefore important to ensure that no malware is introduced in the binary/bytecode.
15	Product passes Malformed Input Testing	Malformed input testing is dynamic testing used to develop a level of confidence in operationally addressing the "unknown unknowns" over communication interfaces that are not readily determined through static analysis.
16	Product passes Structured Penetration Testing	Structured penetration testing is a variant of general penetration testing that is intended to place focus on the weaknesses and vulnerabilities that are dispositioned as acceptable via the Risk Management process. This helps normalize variations across different medical device manufacturer's risk management (MDM RM) processes. (Also see Appendix D of UL 2900-1.)
17	Product passes Software Weakness Analysis	Weakness analysis is intended to identify Common Weakness Enumerations (CWEs), which may not yet have a viable path to successful exploitation (i.e. no known exposure). The analysis of the CWEs is intended to be done within the risk/benefit context of the given medical device.
19	Product passes Static Binary and Bytecode Analysis	Static binary and bytecode analysis has a twofold function. First is for Software Composition Analysis, to determine the components with which weaknesses or vulnerabilities may be associated. The second is to illustrate the relationships among software components and the potential paths from the attack surface to the asset.
20.1	Vendor has established and documented quality management processes	Security is an aspect of software quality. A documented and practiced method by which the quality of goods or services is controlled to meet desired or stated requirements through the application of review techniques and corrective actions during the lifecycle process
20.2	Vendor has established and documented general procurement processes	A documented and practiced method by which suppliers are vetted and selected for the ability deliver goods and services in accordance with desired levels of quality and agreed upon terms as it pertains to security.
20.3	Vendor has established and documented procurement risk management processes	A defined systemic approach to anticipate, identify, evaluate, and manage potentially unfavorable deviations in order to reduce or eliminate negative impacts as it pertains to security. This is intended to minimize the likelihood of supply chain attacks.
20.4	Vendor has established and documented product update release and patch management processes	A documented and practiced method to timely identify, acquire, test, distribute, and install code changes for existing applications to correct known code weaknesses or deliver enhanced quality or software capabilities. This applies to adaptive, perfective, corrective, or preventive software changes.

Table A1.1 Continued on Next Page

Table A1.1 Continued

Reference	Description	Rationale
20.5	Vendor has established and documented product decommissioning processes	A documented and practiced method to eliminate latent risks as an asset leaves the organization that includes ensuring confidential data is migrated and maintained in accordance with retention requirements. All sensitive data, including documents, applications, accounts, settings, and the like is eliminated consistent with data destruction practices and the zeroization requirements in UL 2900-1, and the assets are disposed of properly.
20.6	Vendor has established and documented packaging and shipment processes	A documented and practiced method to prepare and transport products to comply with regulatory standards, track goods while in transit, and prevent the damage or loss of goods during transit. This is intended to drive inclusion of distribution system vulnerabilities in the threat model of the product. This is also intended to trigger consideration of security considerations in distribution of "break the glass" (aka security override) instructions.



333 Pfingsten Road
Northbrook, Illinois 60062–2096
847.272.8800

For other locations in the UL family of companies,
please visit [UL.com/contact](https://www.ul.com/contact)